Mindsmiths	Encryption Policy			
	ID	EP	**Author**	Hrvoje Kovačević
	Version	1.1	**Date**	21.06.2021.

Content

History of Changes in documented information 1

Purpose and Scope 2

Background 2

Policy 2

History of Changes in documented information

Date	Created by	ID	Version	Change
13.02.2020	Hrvoje Kovačević	EP	1.0	First Version
21.06.2021	Hrvoje Kovačević	EP	1.1	Update
04.02.2022	Ante Malenica	EP	1.2	Update

Mindsmiths	Encryption Policy			
	ID	EP	**Author**	Hrvoje Kovačević
	Version	1.1	**Date**	21.06.2021.

Purpose and Scope

This policy defines organizational requirements for the use of cryptographic controls, as well as the requirements for cryptographic keys, in order to protect the confidentiality, integrity, authenticity, and nonrepudiation of information.

This policy applies to all systems, equipment, facilities, and information within the scope of Mindsmiths' information security program.

All employees, contractors, part-time and temporary workers, service providers, and those employed by others to perform work on behalf of Mindsmiths having to do with cryptographic systems, algorithms, or keying material are subject to this policy and must comply with it.

Background

This policy defines the high-level objectives and implementation instructions for Mindsmiths' use of cryptographic algorithms and keys. It is vital that Mindsmiths adopt a standard approach to cryptographic controls across all work centers in order to ensure end-to-end security, while also promoting interoperability. This document defines the specific algorithms approved for use, requirements for key management and protection, and requirements for using cryptography in cloud environments.

Policy

1. Mindsmiths must protect individual systems or information by means of cryptographic controls as defined in Table 1:
2. Except where otherwise stated, keys must be managed by their owners.
3. Cryptographic keys must be protected against loss, change, or destruction by applying appropriate access control mechanisms to prevent unauthorized use and backing up keys on a regular basis.
4. When required, customers of Mindsmiths' cloud-based software or platform offering must be able to obtain information regarding:
    a. The cryptographic tools used to protect their information.
    b. Any capabilities that are available to allow cloud service customers to apply their own cryptographic solutions.
    c. The identity of the countries where the cryptographic tools are used to store or transfer cloud service customers' data.
5. The use of organizationally-approved encryption must be governed in accordance with the laws of the country, region, or other regulating entity in which users perform their work. Encryption must not be used to violate any laws

or regulations including import/export restrictions.

6. All key management must be performed using software that automatically manages access control, secure storage, backup, and rotation of keys. Specifically:
    a. The key management service must provide key access to specifically-designated users, with the ability to encrypt/decrypt the information and generate data encryption keys.
    b. The key management service must provide key administration access to specifically-designated users, with the ability to create, schedule delete, enable/disable rotation, and set usage policies for keys.
    c. The key management service must store and backup keys for the entirety of their operational lifetime.
    d. The key management service must rotate keys at least once every 12 months.

Name of System/Type of Information	Cryptographic Tool	Encryption Algorithm	Key Size
Public Key Infrastructure for Authentication	OpenSSL	AES-256	256-bit key
Data Encryption Keys (“at rest” and “in transit”)	OpenSSL	AES-256	256-bit key
Virtual Private Network (VPN) keys	OpenSSL and OpenVPN	AES-256	256-bit key
Website SSL Certificate	OpenSSL, LetsEncrypt	RSA	2048-bit key

Table 1: Cryptographic Controls

Roles and Responsibilities

Security Engineer

- **Overseeing Security Strategy**: this individual sets the overarching security policies and ensures compliance with legal and regulatory standards.
- **Key Lifecycle Management**: manage the entire lifecycle of cryptographic keys.
- **Technical Implementation**: In the capacity of a Security Engineer, they design and implement secure cryptographic systems and manage technical aspects of encryption and key management.

IT Staff and Developers

- **System Implementation and Maintenance**: IT staff are responsible for implementing encryption as per the guidelines set by the Security Engineer. They handle the practical aspects of key distribution and system updates.
- **Application Integration**: Developers integrate encryption into applications and systems, ensuring that security is embedded in the software development process.

Compliance, Incident Response, and End Users

- **Compliance Monitoring**: This group ensures that encryption and key management practices adhere to internal policies and external regulations.
- **Incident Response**: Handles incidents involving cryptographic systems, investigates breaches, and implements corrective actions.
- **Policy Adherence and Awareness**: End users follow established policies for handling encrypted data and maintain a basic level of security awareness as it pertains to encryption practices.

Key Components

- **Data-at-Rest Encryption**: Encrypt all stored sensitive data using strong, industry-standard algorithms like AES-256.
- **Data-in-Transit Encryption**: Secure data during transmission using protocols like TLS/SSL, ensuring end-to-end encryption where possible.
- **Use of Certified Cryptographic Libraries**: Only utilize cryptographic libraries that

have received certification (such as FIPS 140-2) to ensure reliability and security.
- **Compliance and Standards Adherence**: Align with international and national cryptographic standards and practices.
- **Key Management**: Implement effective key management practices, including secure storage, access control, and regular rotation.

Implementation and Monitoring

- Regular training for staff on secure encryption practices and the importance of using certified libraries.
- Continuous auditing and monitoring to ensure adherence to the policy.

Review and Update

- Periodically review and update the policy to reflect technological advancements, emerging threats, and regulatory changes.